

EU AI Act Governance Platform AI Compliance Assessment Report

System: CV Screening Tool

Risk Classification: HIGH RISK

Report Generated:	17 May 2026, 19:59 UTC
Assessment Framework:	EU AI Act, GDPR Article 35, OWASP LLM Top 10, NIST AI RMF
Classification:	HIGH RISK
DPIA Required:	Yes

Executive Summary

This report presents the results of an AI governance and compliance assessment conducted for **CV Screening Tool**. The system has been classified as **HIGH RISK** under the EU AI Act. System operates in the 'employment' sector which is listed under Annex III of the EU AI Act as High Risk. Automated decision-making without human review increases risk. A total of 14 compliance obligations have been identified. A Data Protection Impact Assessment is mandatory under GDPR Article 35. 7 data protection risks have been identified. The OWASP LLM Top 10 assessment identified 5 security risks with an overall severity of **CRITICAL**. The NIST AI RMF maturity assessment indicates: **Initial — Significant gaps in AI risk management maturity**. A total of 5 compliance gaps require immediate attention.

1. EU AI Act Risk Classification

Risk Tier: HIGH

Justification: System operates in the 'employment' sector which is listed under Annex III of the EU AI Act as High Risk. Automated decision-making without human review increases risk.

DPIA Required: Yes

Compliance Obligations:

- Implement a risk management system (Article 9)
- Establish data governance practices (Article 10)
- Maintain technical documentation (Article 11)
- Enable automatic logging and record-keeping (Article 12)
- Ensure transparency for users (Article 13)
- Implement human oversight measures (Article 14)
- Achieve required accuracy, robustness and cybersecurity (Article 15)
- Register system in EU AI Act database before deployment (Article 16)
- Inform workers and their representatives about AI use
- Ensure non-discrimination in automated hiring decisions
- Conduct Data Protection Impact Assessment (GDPR Article 35)
- Appoint Data Protection Officer if not already in place
- Implement mandatory human review before decisions take effect
- Provide mechanism for individuals to contest automated decisions

2. Data Protection Impact Assessment

This DPIA covers the processing of personal data by 'CV Screening Tool' operating in the employment sector. The system processes names, CVs, contact details belonging to job applicants for the purpose of automated candidate shortlisting. Based on the EU AI Act risk classification of 'high' and the nature of data processed, a DPIA is mandatory under GDPR Article 35. This assessment has identified 7 risks requiring mitigation measures.

Risks Identified:

- Discriminatory automated decisions affecting employment opportunities
- Unlawful processing of candidate personal data without valid legal basis
- Lack of transparency denying candidates right to explanation
- Automated decisions made without meaningful human review violating GDPR Article 22
- Data breach exposing personal information of data subjects
- Processing beyond stated purpose violating purpose limitation principle
- Retention of data beyond necessary period violating storage limitation principle

Mitigation Measures:

- Implement data minimisation — collect only data strictly necessary for the stated purpose
- Apply pseudonymisation or anonymisation where technically feasible
- Establish access controls ensuring only authorised personnel access personal data
- Implement encryption of personal data at rest and in transit
- Define and enforce strict data retention periods with automated deletion
- Establish a process for data subjects to exercise their GDPR rights — access, rectification, erasure
- Conduct regular audits of data processing activities
- Train all staff with access to personal data on GDPR obligations
- Inform candidates that automated tools are used in the hiring process
- Provide candidates with right to human review of automated decisions

Recommendation: HIGH PRIORITY: Multiple significant risks identified. Do not deploy this system until all mitigation measures are implemented and independently reviewed. Consult your Data Protection Officer and consider consulting the supervisory authority before deployment.

3. OWASP LLM Top 10 Security Assessment

Overall Security Severity: **CRITICAL**

Security Risks Identified:

- LLM02 - Sensitive Information Disclosure (HIGH): LLM reveals confidential data from training data or context window
- LLM03 - Supply Chain Vulnerabilities (HIGH): Risks from third-party models, datasets, or plugins used in the system
- LLM04 - Data and Model Poisoning (HIGH): Manipulation of training data or fine-tuning process to introduce backdoors
- LLM05 - Improper Output Handling (CRITICAL): LLM output passed to downstream systems without validation or sanitisation
- LLM09 - Misinformation (HIGH): LLM generates plausible but incorrect information used in high-stakes decisions

Security Recommendations:

- LLM02: Avoid including sensitive data in prompts. Implement output filtering. Apply data classification before including in context window.
- LLM03: Vet all third-party models and plugins. Pin model versions. Monitor for supply chain advisories.
- LLM04: Validate training datasets. Monitor model behaviour for unexpected changes. Use differential privacy where possible.
- LLM05: Treat all LLM output as untrusted. Validate and sanitise before passing to downstream systems. Never execute LLM output directly.
- LLM09: Implement human review for high-stakes decisions. Add confidence scoring to outputs. Display uncertainty to end users.

4. NIST AI RMF Assessment

Overall Maturity Level: Initial — Significant gaps in AI risk management maturity

GOVERN Controls:

- GOVERN 1.1: Policies and procedures for AI risk management should be established
- GOVERN 1.2: Roles and responsibilities for AI oversight must be clearly defined
- GOVERN 1.3: AI risk management must be integrated into organisational governance
- GOVERN 2.1: Accountability mechanisms for AI decisions must be established
- GOVERN 4.1: Organisational teams must be trained on AI risk and responsible AI practices
- GOVERN 5.1: Policies for AI transparency and explainability must be documented

MAP Controls:

- MAP 1.1: AI system context and intended use has been documented
- MAP 1.5: Organisational risk tolerance for this AI system should be defined
- MAP 2.1: Scientific and domain expertise has been applied to identify AI risks

- MAP 2.2: Scientific rigour of AI outputs must be assessed
- MAP 3.1: AI system risks to individuals, groups and society must be enumerated
- MAP 3.5: Risks to vulnerable populations must be specifically assessed
- MAP 4.1: 5 security risks identified via OWASP LLM Top 10 assessment
- MAP 5.1: Privacy risks have been identified — DPIA required under GDPR Article 35

MEASURE Controls:

- MEASURE 1.1: AI risk measurement approaches appropriate to the system have been identified
- MEASURE 2.1: AI system testing must include evaluation of bias and fairness metrics
- MEASURE 2.2: Evaluation of AI system explainability must be conducted
- MEASURE 2.3: AI system performance must be measured against defined benchmarks
- MEASURE 2.6: Robustness and adversarial testing must be performed
- MEASURE 2.10: Privacy risk metrics must be tracked and reported
- MEASURE 2.7: Security vulnerabilities have been assessed — critical severity findings require immediate remediation
- MEASURE 2.8: Penetration testing is recommended given critical OWASP findings

MANAGE Controls:

- MANAGE 1.1: Response plans for identified AI risks must be developed and maintained
- MANAGE 1.3: Risk response priorities must be established based on likelihood and impact
- MANAGE 2.2: Mechanisms to sustain AI system oversight must be implemented
- MANAGE 2.4: Incident response procedures for AI-related failures must be documented
- MANAGE 3.1: Risks must be tracked and monitored on an ongoing basis
- MANAGE 3.2: Residual risks must be documented and accepted by accountable stakeholders
- MANAGE 4.1: AI system performance must be monitored post-deployment
- MANAGE 2.1: Multiple security risks require a prioritised remediation roadmap
- MANAGE 3.3: Data protection risks must be reviewed annually or when system changes occur

Compliance Gaps:

- No evidence of completed DPIA — required before deployment
- Security posture is critical — OWASP LLM risks must be addressed
- EU AI Act registration in EU database required before deployment
- Human oversight mechanism must be designed and implemented
- Technical documentation package must be prepared for regulatory review

5. Priority Recommendations

- HIGH: Complete EU AI Act registration before deployment
- HIGH: Implement human oversight mechanism
- HIGH: Complete and document DPIA before processing personal data
- HIGH: Address all Critical OWASP LLM security findings immediately
- REQUIRED: No evidence of completed DPIA — required before deployment
- REQUIRED: Security posture is critical — OWASP LLM risks must be addressed
- REQUIRED: EU AI Act registration in EU database required before deployment

- ONGOING: Review this assessment annually or when system changes significantly
- ONGOING: Monitor EU AI Act guidance as implementing regulations are published